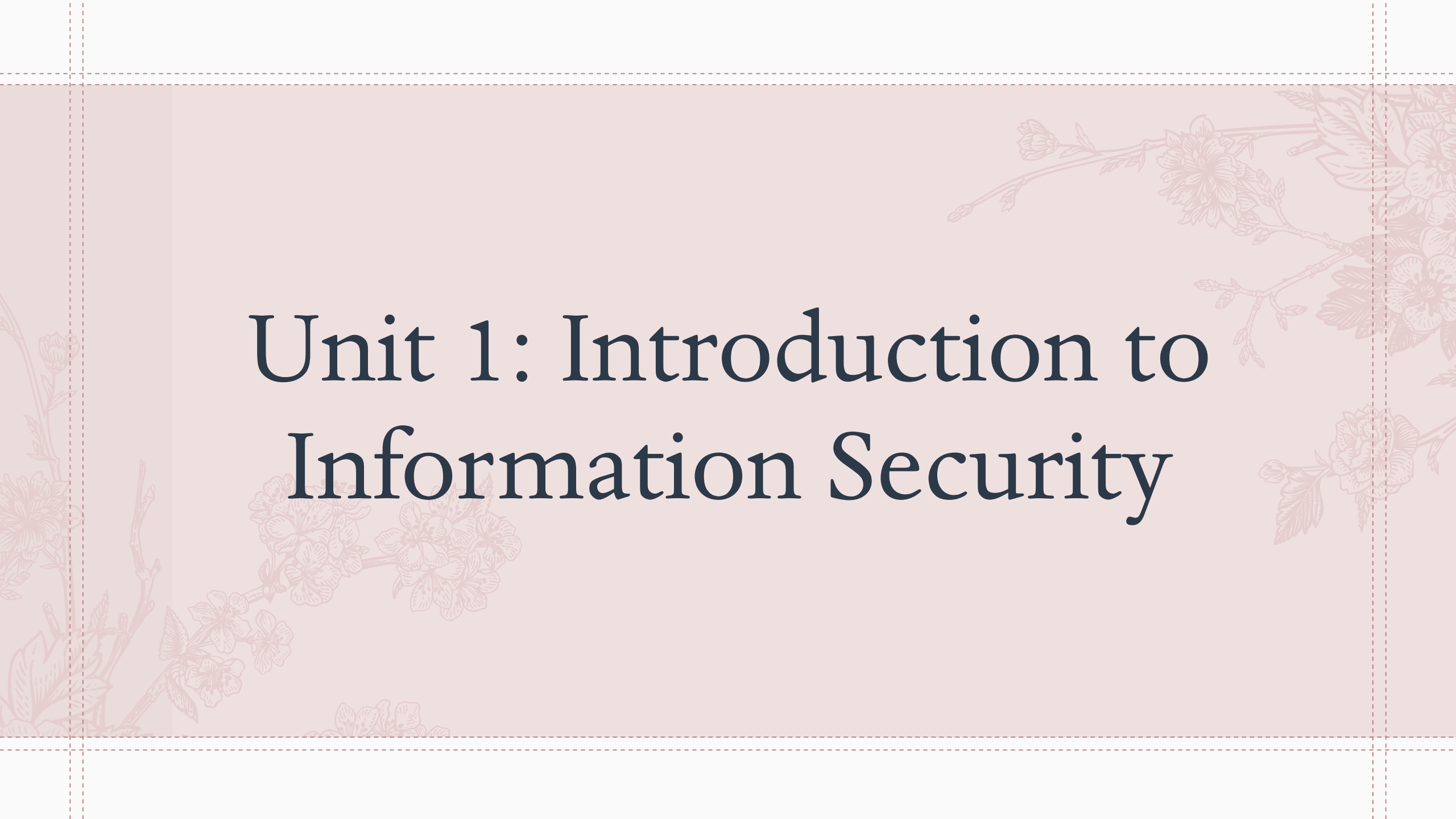




Information Security & Applications

By Maitri Hingu



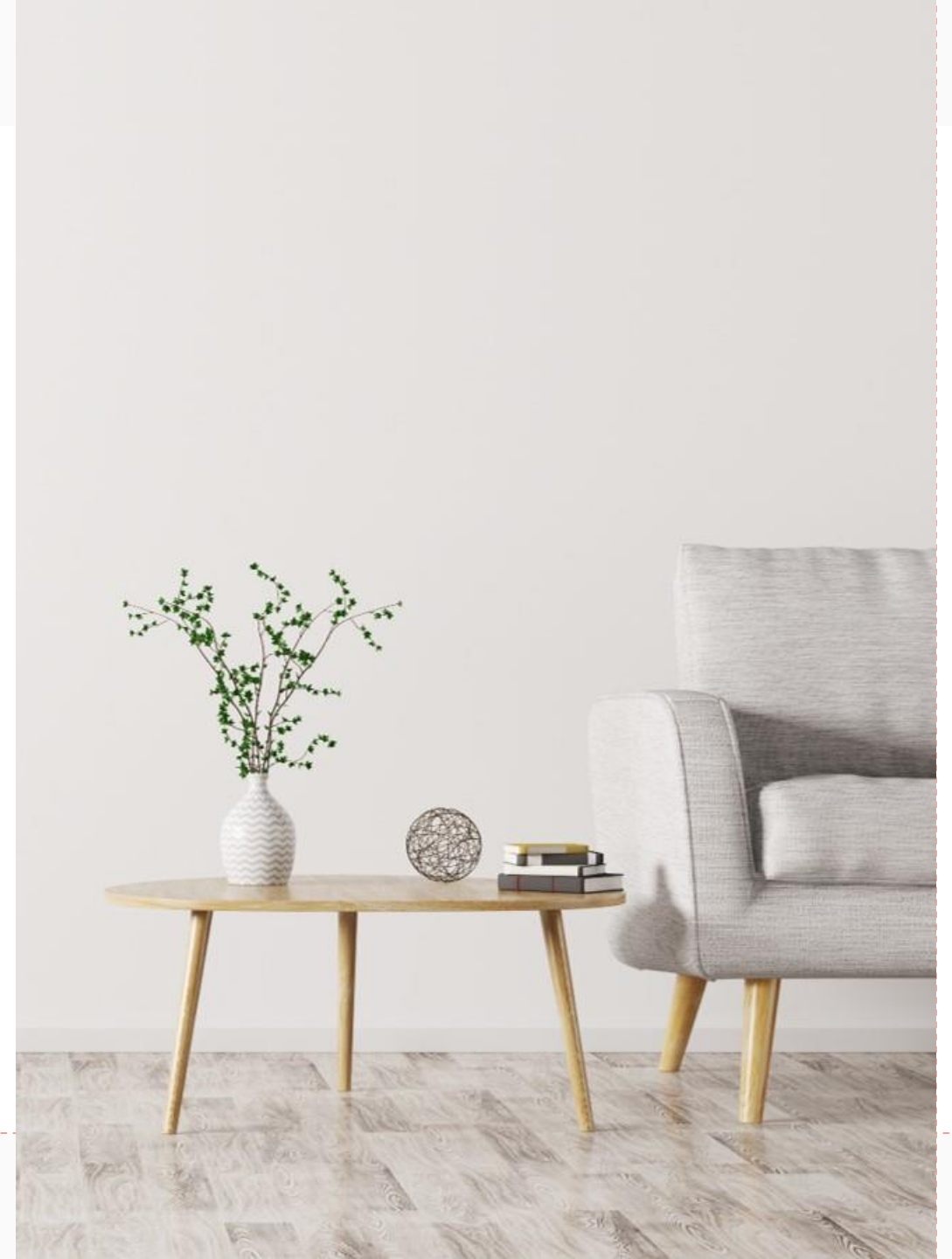
Unit 1: Introduction to Information Security

Agenda

- 1.1 Introduction to Security
- 1.2 Need for Security
- 1.3 The OSI Security Architecture
- 1.4 Security Attacks
 - 1.4.1 Active attacks
 - 1.4.2 Passive Attacks
- 1.5 Security Services
- 1.6 Security Mechanism



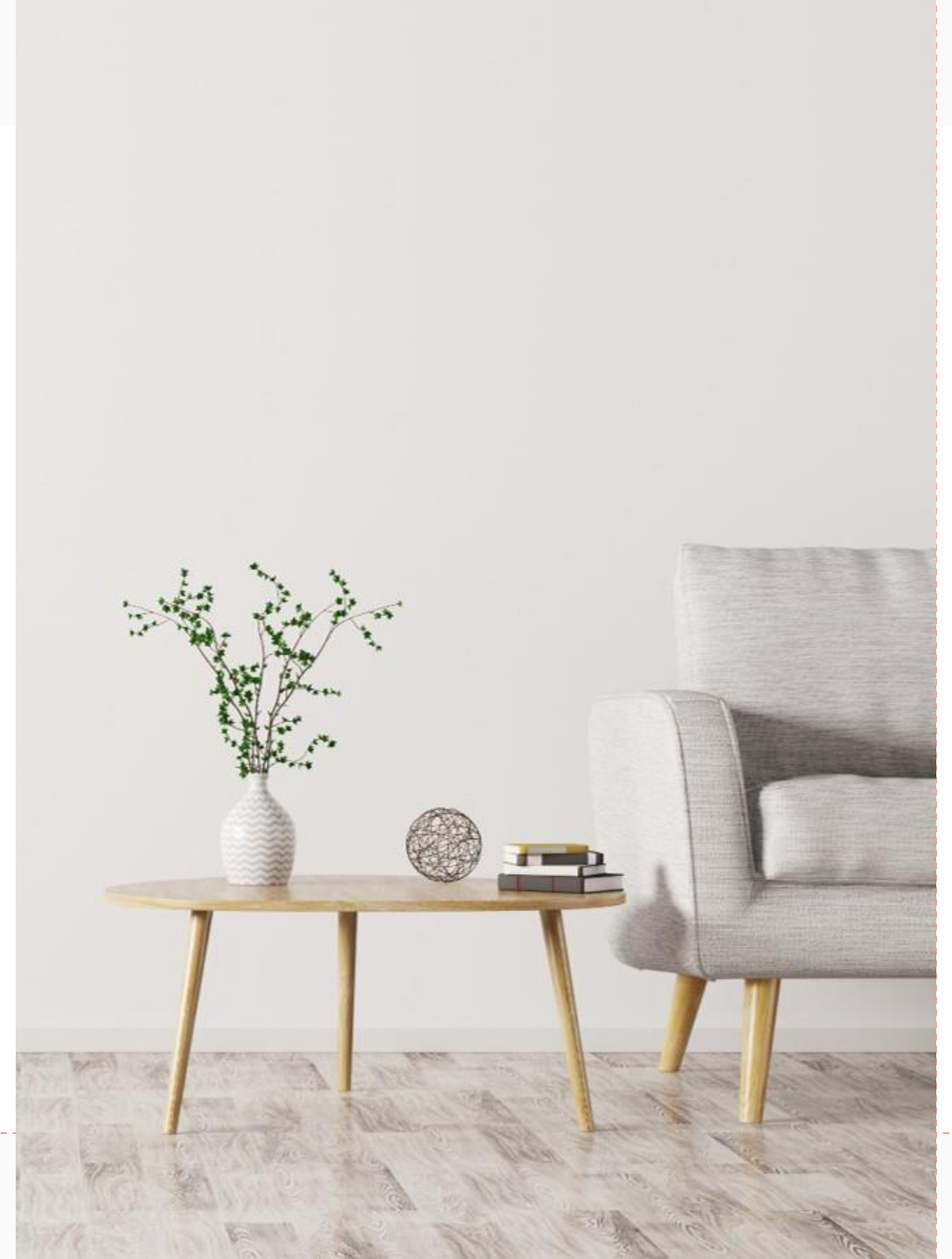
Introduction to Security



Introduction to Security

- ❖ Security refers to the measures and controls put in place to protect information, systems, and assets from unauthorized access, modification, destruction, or disclosure. The main goals of security are to ensure confidentiality, integrity, and availability (CIA) of information.

Need for Security



Need for Security

- ❖ Information Security Requirements Have Changed in Recent Times.
 - **Increased Connectivity:** More devices connected, expanding attack surfaces.
 - **Sophistication of Attacks:** More advanced and varied cyber threats.
 - **Regulatory Requirements:** New laws like GDPR (General Data Protection Regulation) and HIPAA (Health Insurance Portability and Accountability Act) mandate stronger security.
 - **Digital Transformation:** Organizations digitize operations, needing robust security.

Need for Security

- ❖ Traditionally Provided by Physical and Administrative Mechanisms
 - **Physical Security:** Locks, security guards, surveillance.
 - **Administrative Controls:** Access control policies, user training, compliance audits.
- ❖ Use of Computers Requires Automated Tools to Protect Files and Other Stored Information
 - **Antivirus and Anti-malware:** Remove malicious software.
 - **Encryption:** Protects data at rest.
 - **Access Control Systems:** Manage user permissions.
 - **Data Loss Prevention (DLP):** Monitor and control data transfers.

Need for Security

- ❖ Use of Networks and Communications Links Requires Measures to Protect Data During Transmission
 - **Encryption:** Secure protocols like TLS/SSL protect data in transit.
 - **VPNs:** Secure tunnels for data over the internet.
 - **Firewalls and IDS/IPS:** Monitor and control network traffic.
 - **Secure Communication Protocols:** IPsec, SSH, and S/MIME ensure secure data transfer.

Need for Security

- ❖ **Computer Security:** generic name for the collection of tools designed to protect data and to thwart hackers
- ❖ **Network Security:** measures to protect data during their transmission
- ❖ **Internet Security:** measures to protect data during their transmission over a collection of interconnected networks

Our focus is on internet security which consists of measures to prevent, detect, and correct security violations that involve the transmission & storage of information

The OSI Security Architecture



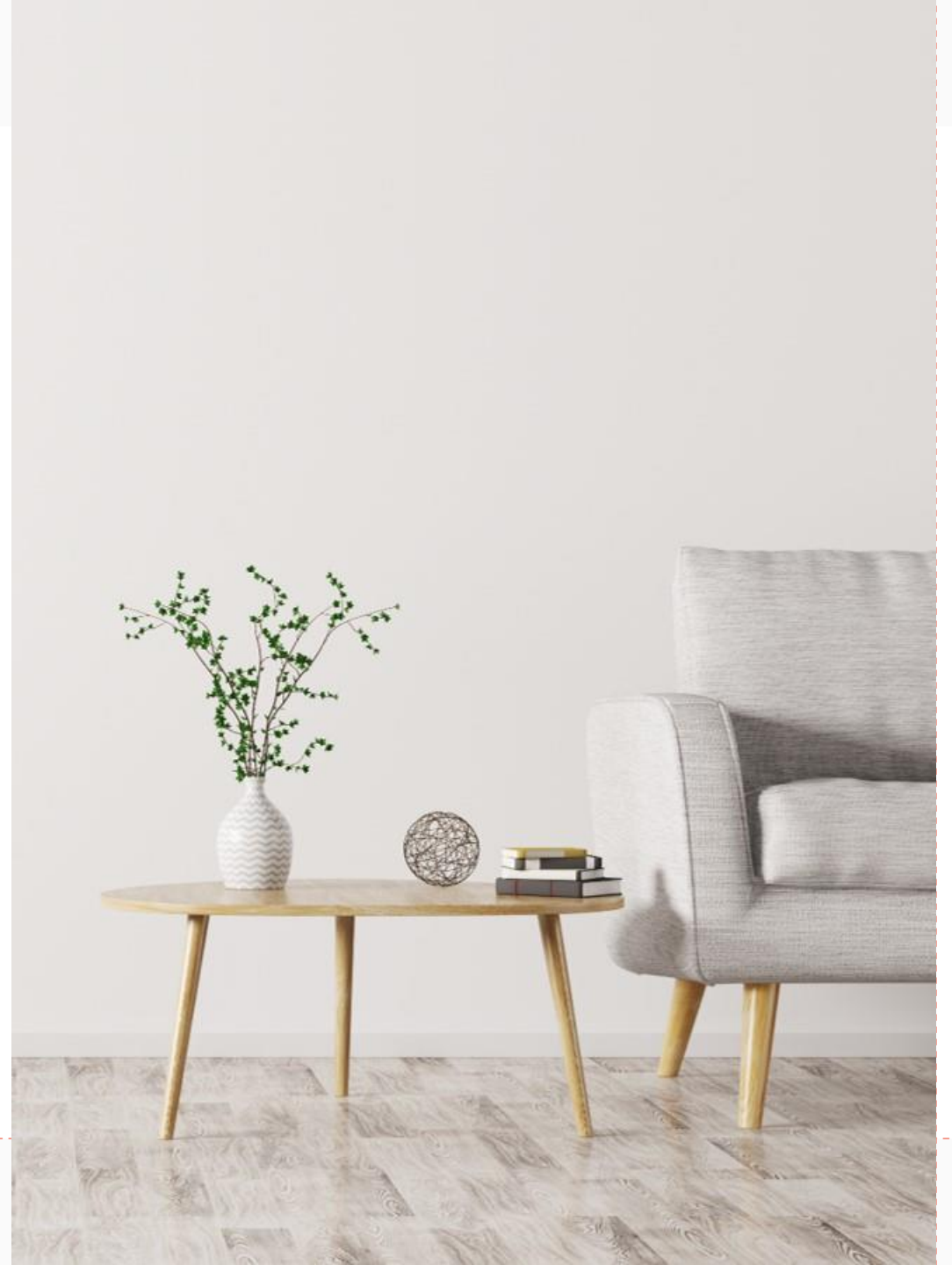
The OSI Security Architecture

- ❖ OSI Security Architecture ITU-T X.800 “Security Architecture for OSI” defines a systematic way of defining and providing security requirements

Consider 3 aspects of information security

- ❖ **Security Attack:** Any action that compromises the security of information owned by an organization.
- ❖ **Security Mechanism:** A process (or a device incorporating such a process) that is designed to detect, prevent, or recover from a security attack.
- ❖ **Security Service:** A processing or communication service that enhances the security of the data processing systems and the information transfers of an organization. The services are intended to counter security attacks, and they make use of one or more security mechanisms to provide the service.

Security Attacks



Security Attacks

- ❖ Any action that compromises the security of information owned by an organization
- ❖ Information security is about how to prevent attacks, or failing that, to detect attacks on information-based systems
- ❖ Often threat & attack used to mean same thing
- ❖ Have a wide range of attacks
- ❖ Generic types of attacks
 1. Passive Attack
 2. Active Attack

Passive Attacks

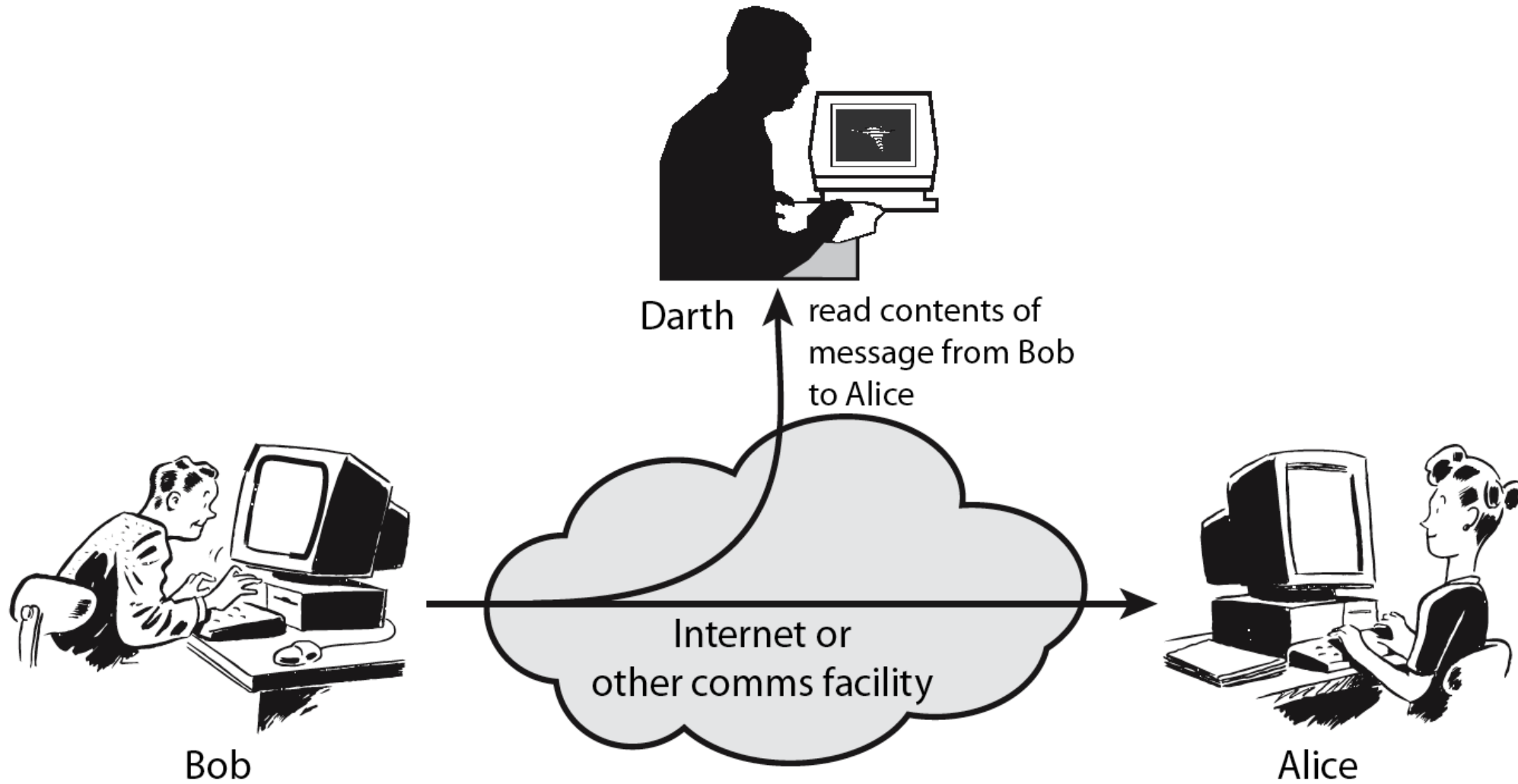
❖ **Passive Attacks:** Eavesdropping or Monitoring of Transmissions

- To Obtain Message Contents, Or Monitor Traffic Flows

Passive attacks are very difficult to detect because they do not involve any alteration of the data. Thus, the emphasis in dealing with passive attack is on prevention rather than detection by encryption.

Passive Attacks

16

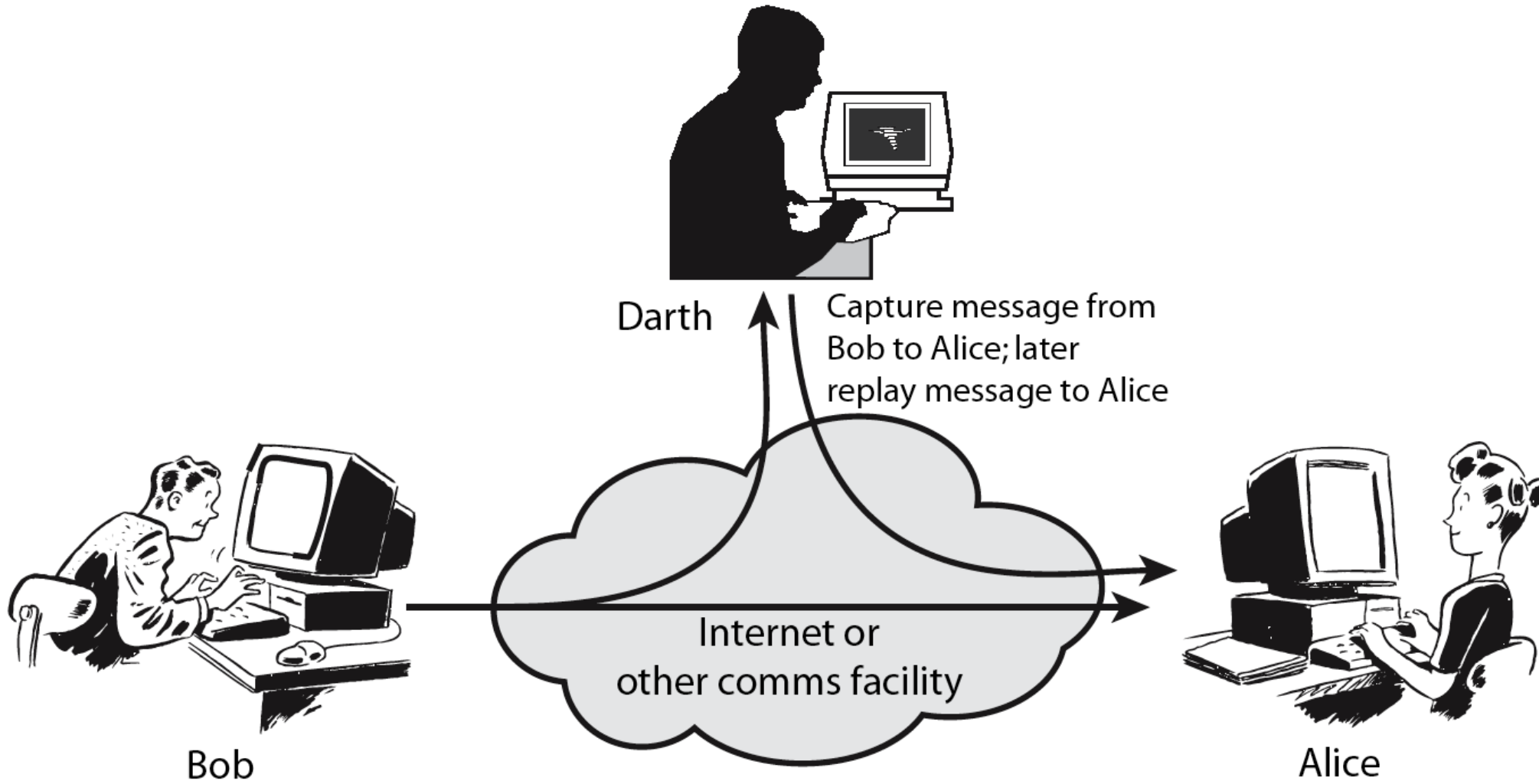


Active Attacks

- ❖ **Active Attacks:** Modification of Data Stream to,
 - **Masquerade:** When one entity pretends to be a different entity.
 - **Replay Previous Messages:** Passive capture of a data unit and its subsequent retransmission to produce an unauthorized effect.
 - **Modify Messages In Transit:** Some portion of a legitimate message is altered, or that messages are delayed or reordered to produce an unauthorized effect.
 - **Denial Of Service:** Inhibits the normal use or management of communication facilities.

Active Attacks

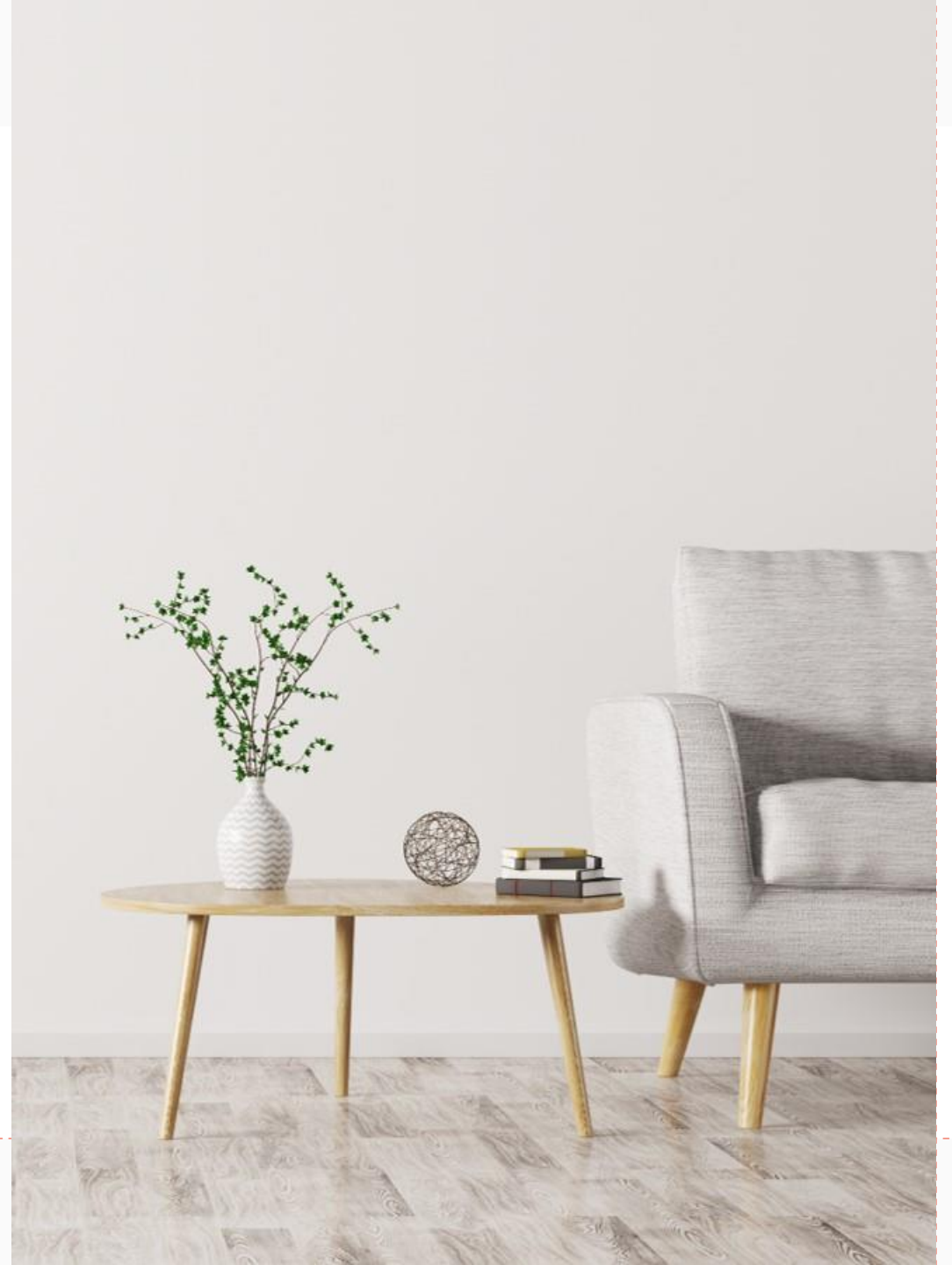
18



Security Attacks

- ❖ **Eavesdropping:** Information remains intact, but its privacy is compromised.
- ❖ **Tampering:** Information in transit is changed or replaced and then sent on to the recipient.
- ❖ **Impersonation:** Information passes to a person who poses as the intended recipient. Impersonation can take two forms:
 - **Spoofing:** A person can pretend to be someone else.
 - **Misrepresentation:** A person or organization can misrepresent itself.

Security Service



Security Service

- ❖ Enhance security of data processing systems and information transfers of an organization
- ❖ Intended to counter security attacks
- ❖ Using one or more security mechanisms
- ❖ Often replicates functions normally associated with physical documents
- ❖ i.e., Which have signatures, dates; need protection from disclosure, tampering, or destruction; be notarized or witnessed; be recorded or licensed

Security Service

- ❖ **X.800:** “A service provided by a protocol layer of communicating open systems, which ensures adequate security of the systems or of data transfers”
- ❖ **RFC 2828:** “A processing or communication service provided by a system to give a specific kind of protection to system resources”

Security Services (X.800)

- ❖ **Authentication:** assurance that the communicating entity is the one claimed
- ❖ **Access Control (Authorization):** prevention of the unauthorized use of a resource
- ❖ **Data Confidentiality:** protection of data from unauthorized disclosure
- ❖ **Data Integrity:** assurance that data received is as sent by an authorized entity
- ❖ **Non-Repudiation:** protection against denial by one of the parties in a communication

Security Services (X.800)

❖ Authentication:

The authentication service is concerned with assuring that a communication is authentic. In the case of an ongoing interaction, such as the connection of terminal to a host, two aspects are involved.

First, at the time of connection initiation, the service assures that the two entities are authentic, that is each entity that it claims to be.

Second, the service must assure that the connection is not interfered with in such a way that a third party can masquerade as one of the two legitimate parties for the unauthorized transmission or reception.

- Peer Entity Authentication
- Data Origin Authentication

Security Services (X.800)

❖ Peer Entity authentication:

Provides corroboration of the identity of a peer entity in association. It attempts to provide confidence that an entity is not performing either a masquerade or an unauthorized replay of a previous connection.

❖ Data Origin Authentication:

Provides corroboration of the source of a data unit. It does not provide protection against the duplication or modification of data units.

E.g.: Email where there are no prior interactions between the communicating entities.

Security Services (X.800)

❖ Data Integrity:

Connection oriented integrity service, one that deals with a stream of messages, assures that messages are received as sent, with no duplication, insertion, modification, reordering or replay.

The destruction of data is also covered under this service.

Connection-less integrity service deals with individual messages without regard to any larger context, generally provides protection against message modification only.

Security Services (X.800)

❖ Non Repudiation:

It prevents either sender or receiver from denying a transmitted message.

Thus, when a message is sent, the receiver can prove that the alleged sender in fact sent the message.

Similarly, when a message is received, the sender can prove that the alleged receiver in fact received the message.

Security Mechanisms (X.800)



Security Mechanisms (X.800)

❖ Security Mechanisms (X.800):

Feature designed to detect, prevent, or recover from a security attack.

No single mechanism that will support all services required.

However one particular element underlies many of the security mechanisms in use is **Cryptographic techniques**.

Security Mechanisms (X.800)

- ❖ **Specific Security Mechanisms:** Encipherment, digital signatures, access controls, data integrity, authentication exchange, traffic padding, routing control, notarization.
- ❖ **Pervasive Security Mechanisms:** Trusted functionality, security labels, event detection, security audit trails, security recovery.

Security Mechanisms (X.800)

❖ Three basic building blocks are used:

- Encryption is used to provide confidentiality, can provide authentication and integrity protection.
- Digital signatures are used to provide authentication, integrity protection, and non-repudiation
- Checksums/hash algorithms are used to provide integrity protection, can provide authentication

One or more security mechanisms are combined to provide a security service

Security Mechanisms (X.800)

❖ Reversible encipherment:

An encryption algorithm that allows data to be encrypted and subsequently decrypted.

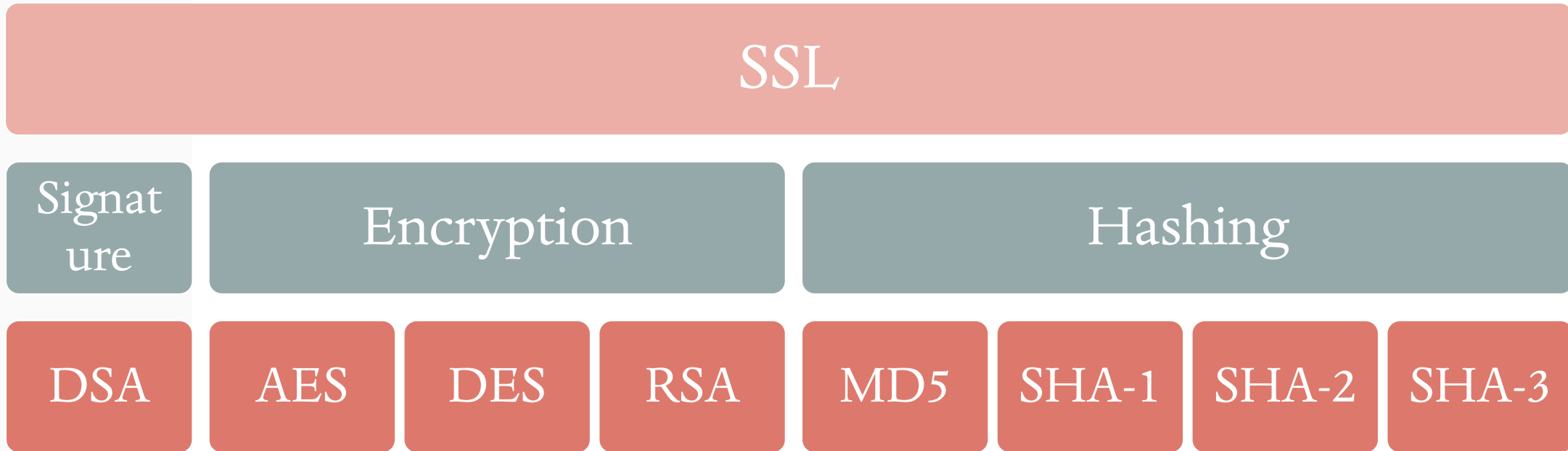
❖ Irreversible encipherment:

Includes hash algorithm and MAC(message authentication codes) which are used in digital signature and message authentication applications.

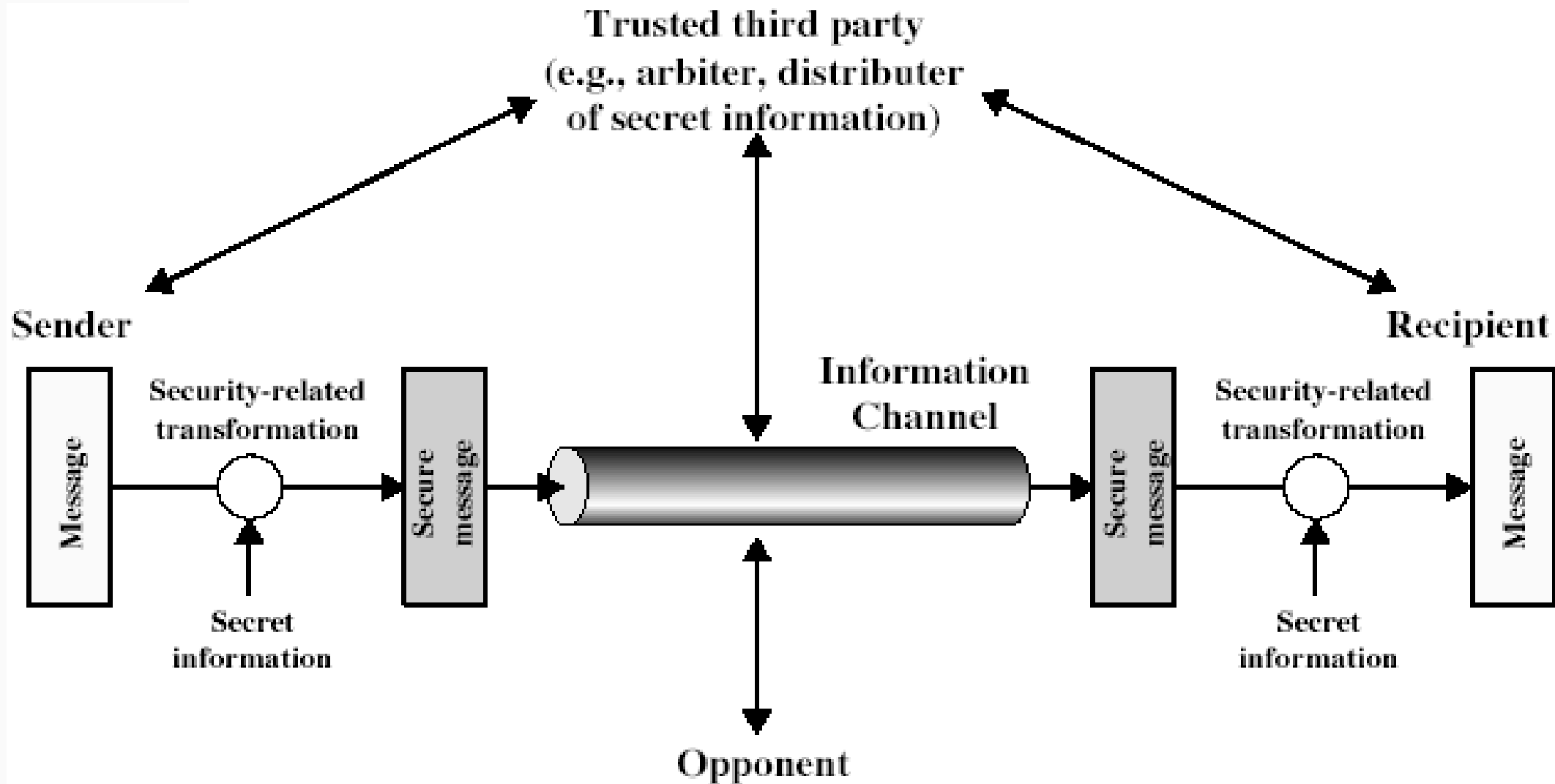
Security Mechanisms (X.800)

Services, Mechanisms, Algorithms

- A typical security protocol provides one or more services
- Services are built from mechanisms
- Mechanisms are implemented using algorithms



Model for Network Security



Model for Network Security

❖ Using this model requires us to:

- Design a suitable algorithm for the security transformation
- Generate the secret information (keys) used by the algorithm
- Develop methods to distribute and share the secret information
- Specify a protocol enabling the principles to use the transformation and secret information for a security service
- Select appropriate gatekeeper functions to identify users
- Implement security controls to ensure only authorised users access designated information or resources

Model for Network Access Security

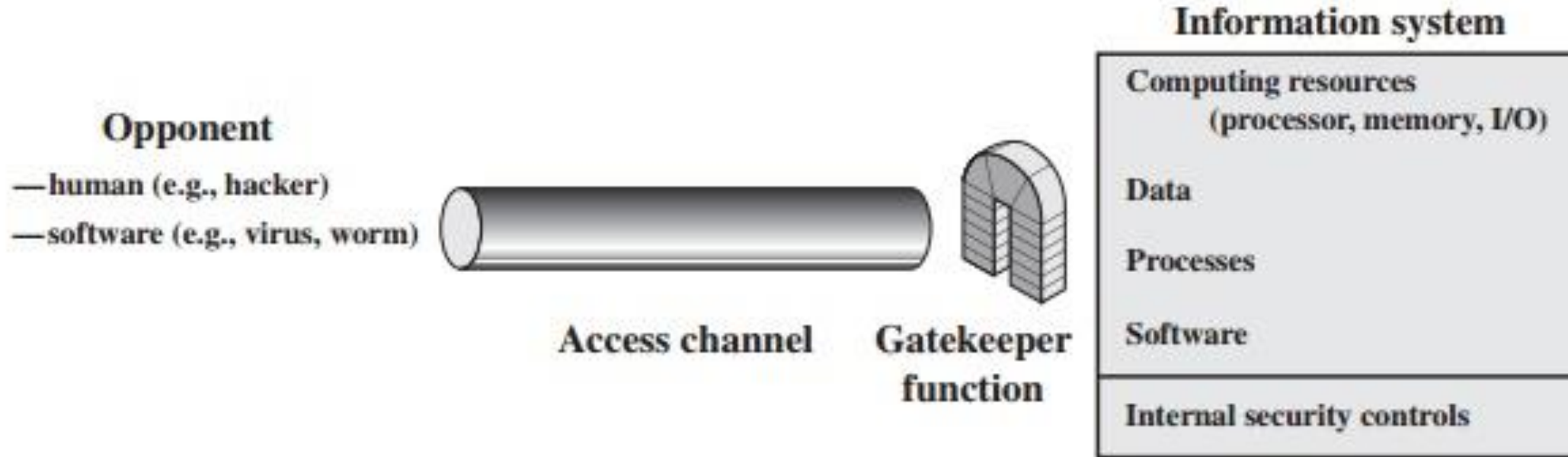


Figure 1.5 Network Access Security Model

Model for Network Access Security

- ❖ Using this model requires us to:
 - Select appropriate gatekeeper functions to identify users
 - Implement security controls to ensure only authorised users access designated information or resources
 - Trusted computer systems may be useful to help implement this model

Thank You

Maitri Hingu

mkhingu@vnsgu.ac.in

